

Internship Task Report: Task 10 Day 10

Date: [18.06.2026]

Intern Name: [Mahek.oza]

(Interns Batch):- Cyber security

Target Website: https://kryosync.netlify.app

Task: Basic Security Review of KryoSync Website:-

Understanding VAPT (Vulnerability Assessment & Penetration Testing)

VAPT is a two-phase process:

1. **Vulnerability Assessment (VA):** This phase involves identifying and cataloging potential security weaknesses in an application or system. It's often automated and aims to find known vulnerabilities.
2. **Penetration Testing (PT):** This phase simulates real-world attacks to exploit the identified vulnerabilities. The goal is to determine the impact of these vulnerabilities and how an attacker could leverage them to gain unauthorized access or cause damage.

Breakdown of Your Requested Testing Areas:

1. OWASP Top 10 Testing

The OWASP Top 10 is a standard awareness document for developers and web application security. It represents the most critical security risks to information systems. A VAPT would thoroughly test for vulnerabilities falling under these categories, which currently include:

- **A01: Broken Access Control:** Testing for instances where users can access data or functionalities they shouldn't be able to.
- **A02: Cryptographic Failures:** Examining if sensitive data is not adequately encrypted, either at rest or in transit.
- **A03: Injection:** This covers a broad range, including SQL Injection, NoSQL Injection, OS Command Injection, etc. (detailed below).
- **A04: Insecure Design:** Identifying flaws in the fundamental design of the application that could lead to security issues.
- **A05: Security Misconfiguration:** Checking for default credentials, open cloud storage, unpatched systems, and other configuration errors.
- **A06: Vulnerable and Outdated Components:** Identifying the use of libraries or frameworks with known vulnerabilities.

- **A07: Identification and Authentication Failures:** Testing for weak password policies, broken session management, and other authentication bypass methods (detailed below).
- **A08: Software and Data Integrity Failures:** Assessing risks related to software updates, critical data, and CI/CD pipelines.
- **A09: Security Logging and Monitoring Failures:** Checking if the application logs security events properly and if monitoring systems can detect and alert on them.
- **A10: Server-Side Request Forgery (SSRF):** Testing if an attacker can trick the server into making requests to an arbitrary domain.

2. SQL Injection (SQLi)

- **What it is:** A type of injection attack where malicious SQL statements are inserted into an input field, which are then executed by the database.
- **Testing:** This involves crafting various SQL queries to see if they can bypass authentication, retrieve sensitive data, or modify/delete data. Tools like Burp Suite or sqlmap are commonly used.

3. XSS (Cross-Site Scripting)

- **What it is:** A web security vulnerability that allows attackers to inject malicious scripts into web pages viewed by other users. There are three main types:
 - **Stored XSS:** Malicious script is stored on the server and executed every time a user visits the affected page.
 - **Reflected XSS:** Malicious script is injected through a URL or form input and is reflected back to the user.
 - **DOM-based XSS:** The vulnerability exists in client-side JavaScript, not in the server-side code.
- **Testing:** Testers attempt to inject script tags, event handlers, and other malicious JavaScript into input fields, URL parameters, and headers to see if they are executed by the browser.

4. CSRF (Cross-Site Request Forgery)

- **What it is:** An attack that tricks a user into performing an unwanted action on a web application where they are authenticated.
- **Testing:** This involves checking if sensitive actions (like changing a password, making a transaction, or deleting data) are protected by CSRF tokens or other mechanisms. If not, an attacker could craft a malicious link or form that, when clicked by an authenticated user, performs the unwanted action without their knowledge.

5. Authentication Bypass

- **What it is:** This occurs when an attacker can gain access to restricted areas or functionalities without proper authentication.
- **Testing:** This can involve:
 - Trying to guess weak passwords or use default credentials.
 - Exploiting logic flaws in the authentication flow (e.g., bypassing a step in the login process).
 - Manipulating session cookies or tokens.
 - Exploiting "forgot password" or "reset password" functionalities.

6. Session Hijacking Analysis

- **What it is:** An attack where an attacker steals a user's session ID to impersonate them and gain unauthorized access to their account.
- **Testing:** This involves:
 - Analyzing how session IDs are generated, transmitted, and stored.
 - Checking for common vulnerabilities like session IDs being predictable, transmitted over unencrypted channels (HTTP), or stored insecurely in cookies.
 - Attempting to steal or manipulate session cookies.

7. Security Hardening

- **What it is:** The process of securing a system by removing or reducing its attack surface. This involves a set of configurations and best practices.
- **Key areas for web applications:**
 - **Server Configuration:** Disabling unnecessary services, using strong encryption (TLS/SSL), configuring firewalls, and keeping software up-to-date.
 - **Application Configuration:** Implementing secure coding practices, input validation, output encoding, disabling debug modes in production, and using secure session management.
 - **Database Security:** Restricting access, using strong passwords, and encrypting sensitive data.
 - **Access Control:** Implementing least privilege principles for users and services.

8. Security Audit Report

- **What it is:** A formal document summarizing the findings of a VAPT.
- **Typical contents:**
 - **Executive Summary:** A high-level overview of the security posture and key findings.
 - **Methodology:** How the assessment and testing were conducted.
 - **Vulnerability Details:** A comprehensive list of all identified vulnerabilities, categorized by severity.

- **Risk Analysis:** An assessment of the potential impact of each vulnerability.
- **Recommendations:** Specific, actionable steps to remediate each vulnerability.
- **Proof of Concepts:** Evidence of exploited vulnerabilities (screenshots, logs).

9. Bug Bounty Style Report with CVSS Score

- **What it is:** A report formatted in a